

Postal address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(11)

Apotea AB

Decision following supervision under the
Data Protection Regulation – Apotea AB
Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection finds that Apotea AB, with organization number 556651-6489, has processed personal data in violation of Article 32.1 of the Data Protection Regulation¹ by failing to implement appropriate technical and organizational measures to ensure an adequate level of security for personal data when using the analytics tool Meta Pixel during the period from June 22, 2020, to May 9, 2022.

The Swedish Authority for Privacy Protection issues Apotea AB a reprimand under Article 58.2 b of the Data Protection Regulation for the violation.

Report on the supervisory case

Background

On May 11, 2022, Apotea AB (Apotea) submitted a notification of a personal data incident to the Swedish Authority for Privacy Protection (IMY). The notification indicated, among other things, that Apotea had used Meta Platforms Ireland Limited's (Meta's) analytics tool Meta Pixel on its website www.apotea.se (the website) to improve its advertising to customers and measure traffic on the website. Apotea stated that a potential personal data incident had occurred because more information than the company was aware of had been transferred to Meta. Apotea discovered the incident through information from an external source.

IMY initiated supervision in May 2022 based on the information contained in the incident notification. The supervision has been limited to the question of whether Apotea has taken appropriate technical and organizational measures in accordance with Article 32 of the Data Protection Regulation. The processing at IMY has taken place through written correspondence.

What Apotea has stated

Apotea has primarily stated the following regarding the issue that IMY is reviewing.

¹ Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

Case number:
IMY-2022-3271

Date:
2024-12-19
Page 1 of 11

Swedish Authority for Privacy Protection
Case number: IMY-2022-3271
2(11)
Date: 2024-12-19

Data Controller

Apotea is the data controller for the processing of personal data that has occurred in connection with

the use of Meta Pixel (formerly Facebook Pixel) and the subsequent sharing of personal data with Meta (formerly Facebook).

Purpose of the processing

The processing of personal data when using Meta Pixel has been for the purposes of interest-based advertising and analysis. The marketing concerned Apotea's range of non-pharmaceutical products through campaign offers and thus involved a limited selection of products from Apotea's product catalog. The marketing has exclusively taken place through advertisements on Meta's social platforms Facebook and Instagram and has only occurred at the group level. Apotea's intention was to use a limited version of Meta Pixel on the website, but on June 22, 2020, the processing was expanded, due to a handling error, by activating the advanced matching (AAM) function of Meta Pixel. On May 9, 2022, Apotea immediately removed the analytics tool from the website after the company received information about the unintentional sharing.

What data was transferred to Meta

The expanded processing of personal data has resulted in a potential disclosure of more personal data than intended. Apotea's intention was to collect data on customers' and website visitors' IP addresses and internal product IDs for products placed in the shopping cart. The expanded use of Meta Pixel has led to the processing also including data on names, addresses, email addresses, phone numbers, and IP addresses of a limited number of customers. Apotea has not shared sensitive personal data, financial data, personal identification numbers, or other privacy-sensitive personal data. Apotea has also not transferred data about customers who have declined the use of cookies or used ad blockers. All data, except for product IDs, have been encrypted through hashing² before being transferred to Meta. Meta has attempted to match the information with its own hashed information, which could only occur if the individual had a Facebook account. After the matching process, the data has been deleted.

All products at Apotea are classified based on the type of product. These classifications consist of, for example, consumer goods, medical devices (including self-tests), over-the-counter medicines, and prescription medicines. In addition to the classification, products are categorized when a new product is added to the product catalog by selecting one of the categories that are entered in the system. This occurs regardless of the use of Meta Pixel and is part of Apotea's internal routines to facilitate regulatory compliance. The categorization is managed directly in the digital system by a specific group within Apotea.

Apotea has given Meta access to a product register with selected internal article IDs for goods that Apotea sells. In this way, it has been possible for Meta to, to a limited extent, link customers' personal data to purchases of products with these article IDs. However, the product register only contained data on consumer goods and had been cleared of product categories deemed sensitive. The register did not contain data on goods classified as medical devices such as self-tests and condoms,

² Hashing is a cryptographic one-way function that can be used to achieve pseudonymization, which is a possible security measure under Article 32 of the Data Protection Regulation, by replacing personal data with a so-called hash value. This means that the replaced personal data is not available in plaintext and that additional information is needed to identify the data subject.

Page 2 of 11

Swedish Data Protection Authority

Diary Number: IMY-2022-3271

3(11)

Date: 2024-12-19

prescription drugs and non-prescription drugs. Meta has thus only been able to link personal data to purchases of goods that do not fall within these categories. It cannot be ruled out that there is a minor margin of error in the limited product catalog where, for example, a few misclassified products could occur. However, it is unlikely that such misclassified products would match a customer since Meta has an automated system that removes such products, and they are therefore excluded before the matching process, meaning they cannot be linked to a customer's purchase.

Scope of the Incident

It is not possible to provide an exact number of registered individuals affected by the incident, as a large part of the data needed for such a calculation has been deleted or is only stored by Meta. It is estimated that a maximum of 238,234–379,959 customers have been affected by the incident. The calculation is based on the number of customers during the relevant period, data from Meta regarding the selection when using the AAM function, and an estimate of how many customers use ad blockers. In practice, the number of affected individuals may be lower since a certain number of customers have declined the use of cookies, and others have lacked accounts on Facebook and Instagram, which is required for a match to be possible.

It is not self-evident that the incident constitutes a personal data breach since it has not been established that there has been unauthorized access to personal data. Apotea has had an agreement with Meta regarding the transfer, and Meta is thus authorized to receive the data. Both the limited and extended transfer to Meta is permitted under the General Data Protection Regulation. Since the decision to expand the processing was not made in accordance with Apotea's internal procedures, the company has chosen to report the incident as a personal data breach.

Technical and Organizational Security

Apotea has had technical and organizational measures in place both before and after the incident to prevent unauthorized and unlawful processing of personal data. The measures have consisted of technical security measures, access restrictions, internal risk assessments, and decision-making procedures. Only three individuals, who needed such access to perform their job duties, have had authorization and access to the settings for the Meta pixel.

Decisions to initiate new or changed personal data processing must be anchored with Apotea's Data Protection Officer. Apotea also has procedures for risk analyses and impact assessments and regularly engages external lawyers for advice on data protection issues. The initial decision to use the Meta pixel was made before the General Data Protection Regulation came into effect. Apotea has previously decided that the AAM function would not be used.

Apotea has conducted an internal investigation of the incident and has been in contact with an external legal representative for legal analysis. The personal data incident has occurred due to a handling error contrary to Apotea's internal procedures. Apotea has security systems and procedures implemented that can identify a change in information collection via the website. However, Apotea has not had a corresponding ability to identify changes in the current case since they were due to changed settings on Apotea's Facebook page.

Page 3 of 11

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3271

4(11)

Date: 2024-12-19

After the incident, Apotea has initiated work to improve and clarify existing procedures to avoid future incidents. Apotea has taken the following measures, among others:

- Implemented new technical security measures, access restrictions, internal risk assessments, and decision-making procedures.
- Introduced additional measures and procedures for changes, which now also include changes made via third-party settings on the website.
- Evaluated the need to procure a service that can identify unintentional sharing of information from the website.
- Trained all staff who process personal data on the General Data Protection Regulation.
- Ceased all transfer of personal data to Meta. Meta has confirmed that all previously transferred data has been deleted.
- Updated all information to customers and website visitors.
- Informed all customers about the extended transfer of personal data via the Meta pixel.

Justification of the Decision

IMY must initially determine whether the General Data Protection Regulation is applicable and whether IMY is the competent supervisory authority. If this is the case, IMY will examine whether Apotea is the data controller and whether the company has taken appropriate security measures according to Article 32 of the General Data Protection Regulation to protect the personal data processed through the Meta pixel, with the AAM function activated, during the period from June 22, 2020, to May 9, 2022.

IMY's Competence

Applicable Provisions

According to Article 95 of the General Data Protection Regulation, the regulation shall not impose any additional obligations on natural or legal persons processing personal data for areas already covered by obligations under the so-called ePrivacy Directive. The ePrivacy Directive has been implemented in Swedish law through the Act (2022:482) on Electronic Communication (LEK), which regulates, among other things, the collection of data through cookies.

According to Chapter 9, Section 28 of LEK, which implements Article 5.3 of the ePrivacy Directive, data may only be stored in or retrieved from a subscriber's or user's terminal equipment if the subscriber or user has access to information about the purpose of the processing and consents to it. Furthermore, it is stated that this does not prevent such storage or access that is necessary to transmit an electronic message via an electronic communications network or that is necessary to provide a service that the user or subscriber has expressly requested. LEK came into force on August 22, 2022. However, during the relevant period in this case, the same requirements applied according to Chapter 6, Section 18 of the Act (2003:389) on Electronic Communication. The Swedish Post and Telecom Authority (PTS) is the supervisory authority according to LEK (Chapter 1, Section 5 of the Regulation [2022:511] on Electronic Communication).

3 Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, on the processing of personal data and the protection of privacy in the electronic communications sector (Directive on Privacy and Electronic Communications).

Page 4 of 11

Swedish Data Protection Authority

Case Number: IMY-2022-3271

5(11)

Date: 2024-12-19

The European Data Protection Board (EDPB) has commented on the interaction between the ePrivacy Directive and the General Data Protection Regulation (GDPR). The opinion states, among other things, that the national supervisory authority designated under the ePrivacy Directive is solely responsible for monitoring compliance with the directive. However, IMY is the competent supervisory authority under the GDPR for processing that is not specifically regulated by the ePrivacy Directive.

On October 7, 2024, the EDPB adopted guidelines regarding the technical scope of Article 5.3 of the ePrivacy Directive. The guidelines indicate, among other things, that a common approach for companies is the use of unique identifiers or persistent identifiers. Such identifiers can be derived from persistent personal data (name, surname, email address, phone number, etc.), which are hashed on the user's device, collected, and shared among several data controllers to uniquely identify a person through various datasets (user data collected through the use of a website or application, customer relationship management related to online or offline purchases or subscriptions, etc.). The guidelines clarify that the fact that the information is entered by the user does not exclude the applicability of Article 5.3 of the ePrivacy Directive, as the information is temporarily stored on the terminal before it is collected. Regarding collection through unique identifiers on websites or mobile applications, the collecting party provides instructions to the browser (through code distributed to the terminal/client) that sends the information. Thus, there is a retrieval of data, and Article 5.3 is applicable. The fact that the collecting party instructing the terminal to send back the information is not the same as the one receiving the information does not exclude the applicability of Article 5.3 of the ePrivacy Directive.

IMY's Assessment

IMY's review focuses on Apotea's use of the Meta pixel, a script-based tool in the form of a piece of code, on its website, where the so-called AAM function was later activated. The activation of the AAM function has resulted in the pixel instructing customers' browsers to collect and hash information in the form of the personal data they provided on the page. Based on this data, a unique identifier has been created, which was temporarily stored in the user's terminal and then transferred to, and thus retrieved by, Meta for matching. The processing in question has thus involved both storage in and retrieval from users' terminal equipment as referred to in Chapter 9, Section 28 of the Electronic Communications Act (LEK), and the corresponding provision in Chapter 6, Section 18 of the Electronic Communications Act (2003:389).

PTS is solely competent to supervise the application of the LEK. However, IMY's review concerns whether Apotea has taken sufficient security measures, which is not specifically regulated in the LEK. IMY is therefore competent to investigate the issue that the supervisory case concerns.

Data Controller

Applicable Provisions

The data controller is, according to Article 4.7 of the GDPR, the entity that alone or jointly with others determines the purposes and means of processing personal data.

4 Opinion 5/2019 on the interaction between the ePrivacy Directive and the General Data Protection Regulation, particularly regarding the competence, tasks, and powers of data protection authorities, adopted on March 12, 2019, paragraphs 68 and 69.

5 EDPB Guidelines 2/2023 on Technical Scope of Art. 5(3) of ePrivacy Directive, paragraphs 61–63.

6 Ibid, paragraph 34.

Page 5 of 11

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3271

6(11)

Date: 2024-12-19

personal data. The fact that purposes and means can be determined by more than one actor means that multiple actors can be joint controllers for the same processing.

The data controller shall, according to Article 5.2 of the General Data Protection Regulation, be responsible for and be able to demonstrate compliance with the principles set out in Article 5.1 (the principle of accountability).

IMY's Assessment

Apotea has stated that the company is the data controller for the processing of personal data that has occurred through the use of the Meta pixel and for the transfer of personal data to Meta.

The investigation shows that Apotea has decided to implement the Meta pixel, a script-based tool in the form of a code snippet that records visitors' actions and transfers the information to Meta, on its website and subsequently activated the AAM function. The purpose of using the Meta pixel has been to enable interest-based advertising and analysis. Apotea has thus determined how the processing shall take place and for what purpose the personal data shall be processed. IMY therefore assesses that Apotea is the data controller for the processing of personal data that has occurred through the use of the Meta pixel with the AAM function activated.

Has Apotea ensured an appropriate level of security for the personal data?

Applicable Provisions

The requirement to take appropriate protective measures

According to Article 32.1 of the General Data Protection Regulation, the data controller shall implement appropriate technical and organizational measures to ensure a level of security that is appropriate in relation to the risk of the processing. This shall, according to the same provision, be done taking into account the latest developments, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, varying in probability and severity, to the rights and freedoms of natural persons. According to Article 32.1, appropriate protective measures, where

appropriate, include

- a) pseudonymization and encryption of personal data,
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services,
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, and
- d) a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

Recital 75 of the General Data Protection Regulation mentions factors to be considered when assessing the risk to the rights and freedoms of natural persons. Among other things, it mentions the loss of confidentiality concerning personal data that is subject to confidentiality obligations as well as whether the processing concerns data about health or sexual life. Furthermore, consideration should be given to whether the processing concerns personal data about vulnerable natural persons, especially children, or whether the processing involves a large amount of personal data and concerns a large number of data subjects.

Page 6 of 11

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3271

7(11)

Date: 2024-12-19

In Recital 76 of the General Data Protection Regulation (GDPR), it is stated that the likelihood and severity of the risk to the rights and freedoms of the data subject should be determined based on the nature, scope, context, and purposes of the processing. The risk should be assessed on the basis of an objective evaluation, through which it is determined whether the data processing involves a risk or a high risk.

Sensitive Personal Data

Data concerning health and sexual life constitute special categories of personal data, so-called sensitive personal data, which are afforded a particularly strong protection under the GDPR. As a general rule, it is prohibited to process such personal data according to Article 9.1 of the GDPR, unless the processing falls under one of the exceptions in Article 9.2 of the Regulation.

Data concerning health is defined in Article 4.15 of the GDPR as personal data relating to the physical or mental health of a natural person, which provides information about that person's health status. In Recital 35 of the GDPR, it is stated that personal data concerning health should include all data relating to a registered person's health condition that provides information about the registered person's past, present, or future physical or mental health status.

The Court of Justice of the European Union (CJEU) has recently established that in a situation where an entity engaged in online sales of medicines that may only be sold by pharmacies, the information that customers provide when purchasing medicines (such as name, address, and details that identify the medicine) constitutes health data, even concerning non-prescription medication. According to the CJEU, the data in question could reveal information about the registered person's health status to the extent that a connection can be established between the medicine, its therapeutic indications or uses, and an identifiable person. Making different interpretations depending on whether the medicine is prescription-only or not is considered incompatible with the GDPR's aim to ensure strong protection for the fundamental rights and freedoms of data subjects and would conflict with, among other things, Article 9.1 of the GDPR. Thus, the information that pharmacy customers provide when purchasing over-the-counter medicines that are only supplied by pharmacies must be regarded as health data, even when it can only be established with some probability and not absolute certainty that the products are intended for these customers. It is also not excluded that, when the products are intended for others, it may be possible to identify and draw conclusions about those persons' health status.

The CJEU has established in the case of Lindqvist that information that a person has injured their foot

and is on partial sick leave constitutes personal data concerning health according to the Data Protection Directive (the directive was repealed by the GDPR). The CJEU stated in the case that, considering the purpose of the Data Protection Directive, the term "data concerning health" should be given a broad interpretation and is to be understood as encompassing data relating to all aspects of a person's health, both physical and mental. The CJEU has in the later ruling *Vyriausioji tarnybinės etikos komisija* determined that the concept of sensitive personal data according to Article 9.1 of the GDPR should be interpreted broadly and assessed that even personal data that indirectly, after

7 CJEU ruling *Lindenapotheker*, C-21/23, EU:C:2024:846, paragraphs 84, 89–91, and 94.

8 Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data.

9 CJEU ruling of 6 November 2003, *Lindqvist*, C-101/01, EU:C:2003:596, paragraphs 50–51.

Page 7 of 11

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-3271

8(11)

Date: 2024-12-19

an intellectual inference or reconciliation, reveals a physical person's sexual orientation constitutes sensitive personal data according to the relevant provision.¹⁰

IMY's Assessment

The processing has involved a high risk and required a high level of protection

The data controller shall take measures to ensure a level of protection that is appropriate based on the risks associated with the processing. The assessment of an appropriate level of protection shall be made taking into account, among other things, the nature, scope, context, and purpose of the processing as well as the risks, of varying degrees of probability and severity, to the rights and freedoms of natural persons.

IMY makes the following assessment of the risks associated with the current personal data processing. Apotea sells a large number of goods of a privacy-sensitive nature, including prescription and over-the-counter medications as well as medical devices and self-tests. Information about individual persons' purchases of such goods often includes privacy-sensitive personal data and could also, in cases where the relevant information pertains to individual customers' health, fall under the broad definition of sensitive personal data. IMY thus concludes that the current processing involves personal data that requires strong protection under the data protection regulation.

Furthermore, the processing has been carried out in a pharmacy operation where the customer can be assumed to have special expectations that their personal data is handled with a high degree of confidentiality. IMY therefore notes that both the nature of the personal data and the context in which it has been processed have resulted in increased risks to the rights and freedoms of the data subjects.

IMY further notes that the current processing has been extensive; Apotea has had a large number of customers during the period the Meta pixel's AAM function has been activated, and the company estimates that a maximum of 238,234–379,959 customers have been affected by the incident.

In summary, IMY assesses that the processing, considering its nature, scope, and context, has posed high risks that have resulted in a requirement for a high level of protection for the personal data. The measures should, among other things, ensure that the personal data is protected against loss of control.

Apotea has not taken sufficient security measures

IMY shall then assess whether Apotea has ensured the high level of protection required for the personal data.

The investigation in the matter shows that Apotea has considered the issue of the Meta pixel's AAM function and decided not to use it, but that this has occurred nonetheless due to a handling error contrary to Apotea's procedures. The activation of the AAM function has resulted in Apotea transferring more data to Meta about customers' purchases than intended. The data that has been

transferred has included customers' names, addresses, email addresses, and phone numbers, as well as Apotea's internal product ID for products purchased by customers.

10 Court of Justice of the European Union ruling of August 1, 2022, Vyriausioji tarnybinės etikos komisija, C-184/20, EU:C:2022:601, pp. 123–127.

Page 8 of 11

Swedish Data Protection Authority

Diary Number: IMY-2022-3271

9(11)

Date: 2024-12-19

However, Apotea has made a selection and categorization of which data would be processed by the Meta pixel and provided Meta with a product register that only contained product IDs for so-called commercial goods. The product register did not contain information about, for example, medical devices such as self-tests and condoms, prescription medications, or over-the-counter medications. Since Apotea only transferred data about the internal product IDs of the products, and no information about, for example, the name of the product, it was only possible to ascertain which product the customer purchased if it was included in the product register. If a customer purchased a privacy-sensitive product, it thus did not emerge from the data transferred to Meta which product the customer had bought, due to the security measures Apotea had implemented prior to the processing. There is no support in the investigation for the occurrence of a miscategorization of products that would have resulted in such privacy-sensitive information being discernible.

IMY notes, however, that a fundamental prerequisite for Apotea to fulfill its obligations under the General Data Protection Regulation (GDPR) is that the company is aware of what processing occurs under its responsibility. Apotea has, for a long period from June 22, 2020, when the AAM function was activated, until May 9, 2022, when the Meta pixel was removed, transferred more data than intended to Meta without discovering it themselves. At the time of the violation, Apotea had security systems and procedures for identifying changes in information collection on the website. The change in the processing of personal data that the activation of the Meta pixel entailed could not be identified because it was due to changed settings on Apotea's Facebook page. IMY finds that the lack of measures to detect changes on the website resulting from third-party settings has meant that Apotea has neither had control over the processing of personal data nor the ability to detect the unintended transfer. IMY assesses that Apotea, therefore, even considering the security measures taken at the time of the violation, cannot be deemed to have taken appropriate technical and organizational measures in relation to the high risks that the processing has entailed. Apotea has thus processed personal data in violation of Article 32.1 of the GDPR.

Choice of Intervention

IMY has the opportunity to impose a number of measures, so-called corrective powers, against those who have violated the GDPR. Article 58.2 and Article 83.2 of the GDPR state that IMY has the authority to impose administrative fines in accordance with Article 83 of the same regulation. If it concerns a minor violation, IMY may, as indicated in Recital 148 of the GDPR, instead of imposing a fine, issue a reprimand according to Article 58.2 b. Consideration shall be given to aggravating and mitigating circumstances in the case, such as the nature, severity, and duration of the violation, as well as previous relevant violations.

The established violation has occurred because Apotea processed personal data with an insufficient level of security, which has led to the company transferring more personal data than intended about a large number of registered individuals to Meta. The transfer has taken place over a long period and was not discovered and addressed until an external party informed Apotea of the deficiency.

Furthermore, the violation has occurred in a pharmacy operation where the registered individuals must be considered to have a legitimate expectation of a high degree of confidentiality. However, Apotea has taken several measures that have limited the intrusion into customers' personal privacy. The company has, among other things, implemented preventive security measures before the processing began, which meant that the unintended transfer did not include data of a privacy-sensitive nature. Furthermore, the personal data has been transferred in hashed, that is, unreadable, format to a single

recipient, and thus it does not involve uncontrolled disclosure where the data has, for example, been shared with many unauthorized parties or been publicly available on the web. In an overall assessment, IMY finds that this is a minor violation as referred to in Recital 148 of the GDPR and that Apotea should therefore receive a reprimand.

This decision has been made by the unit manager Nidia Nordenström after presentation by the lawyer Maja Welanders. In the final handling of the case, the IT and information security specialist Petter Flink has also participated.

Nidia Nordenström

Copy to
Apotea's Data Protection Officer

Page 10 of 11

Swedish Data Protection Authority
Diary Number: IMY-2022-3271
11(11)
Date: 2024-12-19

How to Appeal

If you wish to appeal the decision, you should write to IMY. Indicate in the letter which decision you are appealing and the change you are requesting. The appeal must be received by IMY no later than three weeks from the day you were informed of the decision. If the appeal has been submitted in time, IMY will forward it to the Administrative Court in Stockholm for examination.

You may email the appeal to IMY if it does not contain any privacy-sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.

Page 11 of 11